

Controls and compliance checklist

Select “yes” or “no” to answer the question: *Does Botium Toys currently have this control in place?*

Controls assessment checklist

Yes	No	Control
☐	☒	Least Privilege
☐	☒	Disaster recovery plans
☐	☒	Password policies
☐	☒	Separation of duties
☒	☐	Firewall
☐	☒	Intrusion detection system (IDS)
☐	☒	Backups
☒	☐	Antivirus software
☐	☒	Manual monitoring, maintenance, and intervention for legacy systems
☐	☒	Encryption
☐	☒	Password management system
☒	☐	Locks (offices, storefront, warehouse)
☒	☐	Closed-circuit television (CCTV) surveillance
☒	☐	Fire detection/prevention (fire alarm, sprinkler system, etc.)

Select “yes” or “no” to answer the question: *Does Botium Toys currently adhere to this compliance best practice?*

Compliance checklist

Payment Card Industry Data Security Standard (PCI DSS)

Yes	No	Best practice
☐	☒	Only authorized users have access to customers’ credit card information.
☐	☒	Credit card information is stored, accepted, processed, and transmitted internally, in a secure environment.
☐	☒	Implement data encryption procedures to better secure credit card transaction touchpoints and data.
☐	☒	Adopt secure password management policies.

General Data Protection Regulation (GDPR)

Yes	No	Best practice
☐	☒	E.U. customers’ data is kept private/secured.
☒	☐	There is a plan in place to notify E.U. customers within 72 hours if their data is compromised/there is a breach.
☐	☒	Ensure data is properly classified and inventoried.
☒	☐	Enforce privacy policies, procedures, and processes to properly document and maintain data.

System and Organizations Controls (SOC type 1, SOC type 2)

Yes	No	Best practice
-----	----	---------------

- | | | |
|-------------------------------------|-------------------------------------|--|
| ☐ | ☒ | User access policies are established. |
| ☐ | ☒ | Sensitive data (PII/SPII) is confidential/private. |
| ☒ | ☐ | Data integrity ensures the data is consistent, complete, accurate, and has been validated. |
| ☐ | ☒ | Data is available to individuals authorized to access it. |
-

Recommendations (optional): In this section, provide recommendations, related to controls and/or compliance needs, that your IT manager could communicate to stakeholders to reduce risks to assets and improve Botium Toys' security posture.

To address Botium Toys' current high risk situation, the IT department should prioritize optimizing its security architecture by enforcing strict access controls. Implementing the principles of least privilege, this means that employees should only have minimum access to accomplish a task. Another design principle is separation of duties, this is to ensure that critical actions require multiple people to avoid the abuse of power. These controls are crucial for SOC compliance, as current employee access to internal data and customer PII/SPII presents a significant risk.

To further strengthen the security posture, Botium Toys must implement data encryption to protect credit card details during processing and storage, which fulfills PCI DSS requirements and ensures the confidentiality and integrity of data.

Additionally, deploying an Intrusion Detection System alongside an existing firewall follows the "defense in depth" principle by creating multiple layers of security to monitor threats in real time

To improve operational resilience, the company must establish disaster recovery plans and automated regular backups, which are essential components of business continuity. The IT department should also address its legacy systems, while the systems

are monitored and maintained, no mention that a schedule is in place for such procedures.